TECHNICAL DETAIL

Title	Stored Cross-Site Scripting (Stored XSS) via Update Setting Feature
Reporter	Daffa Rahadya Atmawiguna (rahadya.daffaa@gmail.com)
Date	2025-12-28
Affected Asset	https://bertani.my.id/pengaturan
Severity	Medium
CVSS Score	5.4 CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:U/C:L/I:L/A:N
Proof of Concepts	Please see Steps to Reproduce section

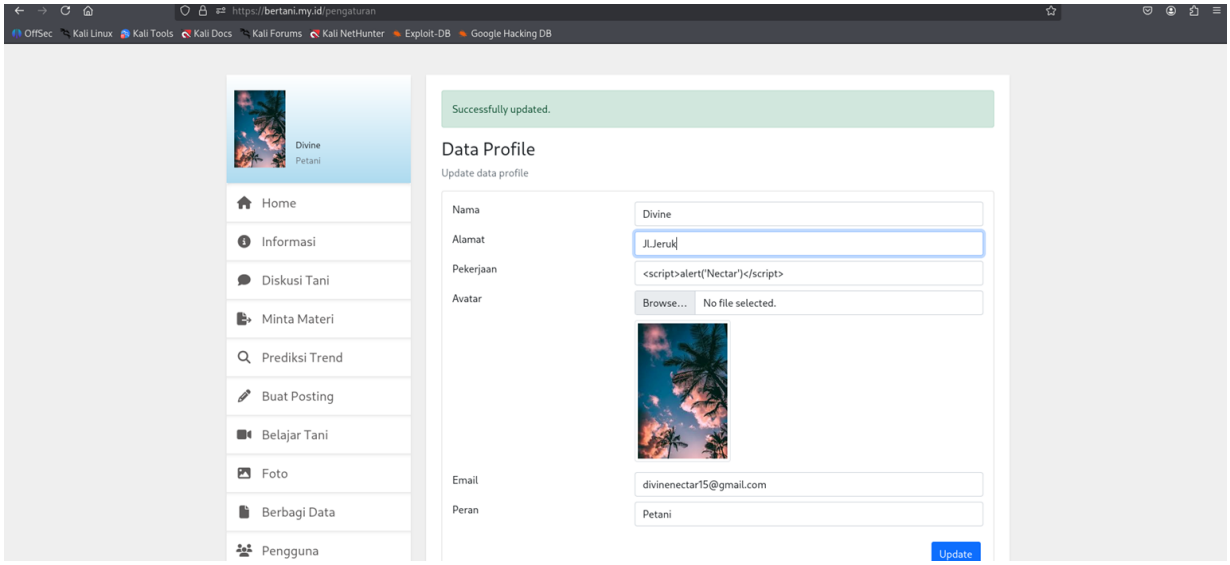
SUMMARY

Terdapat celah keamanan Stored Cross-Site Scripting (XSS) pada fitur pengaturan profil di URL https://bertani.my.id/pengaturan. Kerentanan ini terjadi karena aplikasi tidak melakukan output encoding yang memadai pada parameter pekerjaan. Akibatnya, penyerang dapat menyuntikkan payload JavaScript yang akan tersimpan secara permanen di server dan tereksekusi secara otomatis di sisi browser pengguna lain saat mereka mengunjungi halaman profil penyerang di https://bertani.my.id/user

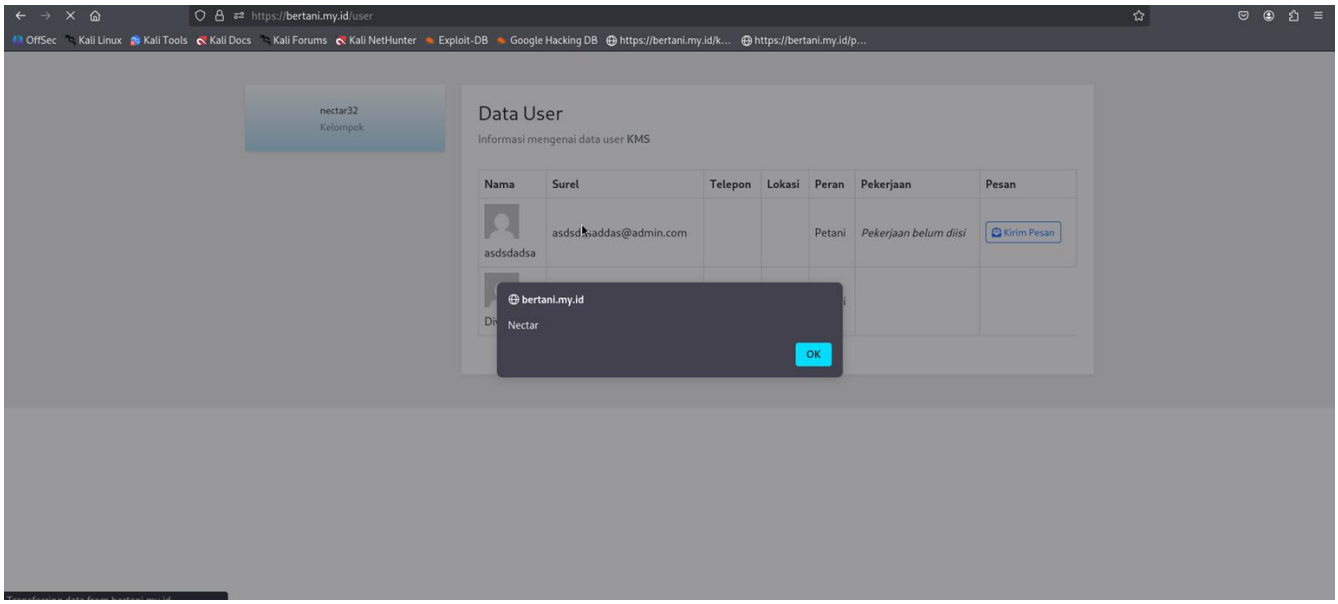
STEPS TO REPRODUCE

1. Login ke Akun anda sebagai user di URL https://bertani.my.id/login

2. buka URL https://bertani.my.id/pengaturan lalu masukkan payload XSS pada input Pekerjaan sebagai contoh disini saya masukan <script>alert("Nectar")</script> lalu update



3. Buka URL https://bertani.my.id/user dan tampilan user lain akan terpengaruh



EXPECTED RESULT

Saat user mengunjungi https://bertani.my.id/user, payload tersebut tidak boleh berjalan. Aplikasi seharusnya melakukan encoding pada karakter khusus sehingga payload hanya muncul sebagai teks biasa di layar (misalnya muncul tulisan <script>alert(“Nectar”)</script> di profil, bukan menjalankan kodenya).

ACTUAL RESULT

Saat user mengunjungi https://bertani.my.id/user, payload JavaScript yang disuntikkan tereksekusi secara otomatis oleh browser, memunculkan jendela peringatan (alert) atau mencuri data sensitif.

IMPACT

1. Session Hijacking: Penyerang dapat mencuri *session cookies* pengguna lain yang mengunjungi halaman profilnya, memungkinkan pengambilalihan akun tanpa kredensial.

2. Defacement & Phishing: Kemampuan untuk menyuntikkan elemen HTML palsu atau mengalihkan (*redirect*) pengguna ke situs berbahaya (phishing) melalui JavaScript

RECOMMENDATION

Aplikasi harus menerapkan Output Encoding pada input pengguna sebelum ditampilkan kembali. Karakter khusus harus dikonversi menjadi HTML Entities:

- < menjadi <
- > menjadi >

REFERENCES

1. OWASP Cross Site Scripting (XSS): https://owasp.org/www-community/attacks/xss/
2. CWE-79 (Improper Neutralization): https://cwe.mitre.org/data/definitions/79.html